OpenClaw Security Monitor

User Guide — v1.5.3

What It Is

A free, open-source macOS menu-bar app that continuously watches your Mac for signs of compromise, privilege escalation, and persistence attacks. It runs 16 independent security checks in the background and can automatically lock your OpenClaw gateway the moment a critical threat is detected.

Requires: macOS 12+. The kill-switch feature requires the OpenClaw gateway. All other monitors work standalone.

Installation

1. 1. Download `OpenClawMonitor-1.5.3.dmg` from the GitHub releases page
2. 2. Open the DMG — drag `OpenClawMonitor` to `/Applications`
3. 3. **First launch:** right-click → **Open** (bypasses Gatekeeper — app is not notarized)
4. 4. The app appears as a menu-bar icon. No Dock icon by design.

Uninstall: Quit the app → delete `/Applications/OpenClawMonitor.app` → optionally delete `~/.openclaw/`

Auto-Updates

The app checks GitHub for new releases **on every launch and every 24 hours**. When a newer version is found:

1. 1. The DMG downloads silently in the background (~42 MB)
2. 2. A dialog appears: **"OpenClaw Monitor vX.X.X is ready to install — Install Now?"**
3. 3. Clicking **Install Now** mounts the DMG — drag to Applications to complete the update

The tray menu item also shows the update status and opens the DMG directly once downloaded.

Dashboard

Click the tray icon → **Open Dashboard** to see:

- **Security Score (0–100)** — drops 25 pts per Alert, 5 pts per Warning; 0 when kill switch is engaged
- **Sparkline** (▁▂▃▄▅▆▇) — last 24 score readings at a glance
- **16 monitor rows** — name, state (OK / Warning / Alert / Starting), detail message, last checked time
- **Kill switch panel** — appears in red when engaged; shows the triggering event with Disengage and Clear buttons
- **Pause All / Resume** — stops all polling during maintenance (e.g., installing software)

The 16 Monitors

Monitor	What It Checks	Kill Switch
Gateway Health	OpenClaw gateway HTTP health endpoint (every 15s)	—
File Integrity	SHA-256 hashes of 17 critical files: SSH keys, auth tokens, config files, /etc/hosts	✓ critical files
Alert Log	New entries in ~/.openclaw/security-alerts.log	—
Egress Rules	macOS pf firewall anchor loaded; auto-reapplies if missing	—
Auth Patches	Minimum number of patched auth files present	—
Namespace Isolation	Only expected processes in OpenClaw namespace	—
Config Permissions	openclaw.json and gateway.env are chmod 600	—
Network Exposure	No unexpected open ports	—
Token Age	Gateway token not older than 30 days	—
Launch Agents	No new .plist files in ~/Library/LaunchAgents	✓
Binary Integrity	Gateway binary SHA-256 unchanged	✓
TCC Permissions	No app newly granted camera/mic/screen/contacts access	—
Sudo Activity	New sudo usage in system log (every 60s)	—
System Posture	SIP enabled · Gatekeeper on · No auto-login · Firewall on · No new admin accounts · SSH/Screen Sharing off	✓ new admin only
Cron Jobs	No new entries in crontab / /etc/cron.d / /etc/periodic	—
System Extensions	No new system extension bundles loaded	—

Default Monitored Files (FIM)

`SOUL.md`, `IDENTITY.md`, `AGENTS.md`, `TOOLS.md`, `openclaw.json`, `gateway.env`, gateway plists, `.zshrc`, device identity files, auth-profiles.json, auth.json, `~/.ssh/authorized_keys`, SSH private keys, `/etc/hosts`

Kill Switch

When triggered, the kill switch:

1. 1. Records the event with timestamp, monitor, trigger, and details
2. 2. Locks the gateway via `launchctl unload` (persists across reboots)
3. 3. Turns the tray icon red and shows a Dashboard banner
4. 4. Optionally sends an email alert

Triggers: New LaunchAgent plist · Binary hash change · Critical FIM file change · New admin account

Bypass list (Settings → Kill Switch Rules): monitors in this list still alert but do not lock the gateway. Useful for monitors that frequently fire on developer machines (e.g., Binary Integrity during active development).

Disengaging: Dashboard → Disengage Kill Switch. The gateway restarts and monitoring resumes.

If `LockAsync` fails, the kill switch retries once after 2 seconds and logs a `LOCK_FAILED` event if it still fails.

Email Alerts

Configure in **Settings → Email Alerts**. Sent on every kill switch fire.

Field	Example
SMTP Host	`smtp.gmail.com`
Port	`587` (STARTTLS) or `465` (SSL)
Username	your Gmail address
Password	Gmail App Password (not your account password)
From / To	alert sender and recipient addresses

Gmail: Go to myaccount.google.com → Security → 2-Step Verification → App passwords → create one for "Mail". Use that 16-character password here.

Emails are best-effort — SMTP failures are swallowed silently. The kill switch fires regardless.

Settings Reference

Monitor Intervals (all in seconds unless noted)

Setting	Default	Range
Gateway Health	15s	5–600
File Integrity	60s	10–3600
Alert Log	30s	5–600
Egress / Patches / Namespace / Permissions / Exposure	300s each	30–3600
Token Age	6h	5m–24h
Launch Agents / Binary Integrity / System Posture / Cron Jobs	300s each	30–3600
Sudo Activity	60s	30–600
System Extensions	600s	60–3600
Token Max Age	30 days	7–365

Other Settings

- **Monitored Files** — add/remove files for FIM; mark Critical to trigger kill switch on change
- **Kill Switch Bypass** — comma-separated monitor names to exclude from gateway lock
- **Email Alerts** — SMTP configuration (see above)
- **Start Minimized** — don't open Dashboard on launch (default: on)
- **Show Notification** — macOS notification on kill switch fire (default: on)

Limitations & What It Cannot Protect Against

Cannot protect against	Why
Kernel rootkits	Operate below userspace — can hide files, processes, and network connections from all userspace tools including this app
Physical access attacks	Someone with your login and physical access can bypass software protections
Attacks faster than the poll interval	Default intervals of 1–10 minutes mean a fast automated attack could complete before the next check
In-memory malware	No filesystem footprint = nothing for FIM to detect
Zero-day privilege escalation	An attacker who silently gains root can disable or modify this app before it detects anything
Social engineering	If you run a malicious command yourself, the app sees the result but cannot stop the action
Between-restart blind spot	Baselines (LaunchAgents, admin accounts, cron jobs, extensions) are in-memory and reset on restart — the first check after launch re-establishes them

What it does well: Detecting persistent malware (LaunchAgents, cron, extensions are the most common macOS persistence mechanisms), privilege escalation (new admin account), configuration drift (SIP/Gatekeeper/firewall), high-value file tampering (SSH keys, auth tokens), and providing a full audit trail even when it cannot stop an attack.

Troubleshooting

App blocked by Gatekeeper → Right-click → Open → Open. Only needed once.

Monitor stuck in "Starting..." → Some monitors need Full Disk Access: System Settings → Privacy & Security → Full Disk Access → add OpenClawMonitor.

Kill switch won't disengage → Check that `~/Library/LaunchAgents/ai.openclaw.gateway.hardened.plist` exists. If deleted, reinstall the OpenClaw gateway.

Email not sending → Verify SMTP settings with another client. For Gmail use an App Password. Check `~/.openclaw/security-tray.log` for error messages.

Settings not saving → Fix permissions: `chmod 600 ~/.openclaw/monitor-settings.json && chown $USER ~/.openclaw/monitor-settings.json`

False alerts from software installs → Use **Pause All Monitors** during installation, then Resume. Or add the affected monitor to the Kill Switch Bypass list.

File Locations

Path	Contents
`~/.openclaw/monitor-settings.json`	All settings (chmod 600, integrity-checked)
`~/.openclaw/kill-switch-state.json`	Kill switch state + audit trail (last 200 events)
`~/.openclaw/security-tray.log`	Append-only human-readable event log
`~/.openclaw/monitor-startup-errors.log`	Startup error log

Settings are protected with a SHA-256 integrity sidecar. If the file is tampered with externally, the app falls back to defaults on next load.

OpenClaw Security Monitor v1.5.3 — MIT License

https://github.com/XBS9/openclaw-security-monitor-mac